Access Management Policy

Policy ID: IT-SEC-007 | Version 3.3 | Owner: Identity and Access Management | Effective: 1 March 2026

1. Principles

Access is granted by role and follows the principle of least privilege. Every system has a named system owner who approves access to it.

2. Onboarding

Accounts for new hires are created 3 business days before their start date, once HR has confirmed the joining date in the HR system. Standard role-based access (email, Teams, the HR portal and the applications for the role) is granted automatically. Laptops are shipped to arrive at least 1 business day before the start date.

3. Requesting Access

Request any additional access through an Access Request in the service portal. Requests need approval from your manager and from the system owner. Access to production databases and the production cloud console also needs approval from Information Security, lasts at most 30 days, and must then be renewed with a new request. Standard requests are fulfilled within 2 business days of approval.

4. Access Reviews

System owners review privileged and production access every quarter, and all other access every six months. Access that is not confirmed during a review is removed within 10 business days.

5. Role Changes

When you move to a different team, the access from your old role is removed within 5 business days of the transfer date. Your new manager must request any access the new role needs.

6. Leaving Kestrel

Accounts are disabled within 4 hours of the end of the last working day, or immediately when the departure is involuntary. Mailboxes are kept for 90 days, and the manager can ask for the leaver's email to be forwarded to them for up to 30 days. On request within 30 days, the leaver's OneDrive files are transferred to the manager.

7. Contractors and Vendors

Contractor accounts use the prefix ext-, need a Kestrel employee as sponsor, and expire on the contract end date or after 6 months, whichever comes first. The sponsor must renew the account before it expires. Vendors never get standing access to production; they receive time-limited access through a Privileged Access Request.

8. Shared and Service Accounts

Shared accounts used by people are not allowed. Service accounts must be registered in the CMDB with a named owner, must keep their secrets in the vault, and must have their credentials rotated every 90 days.